

BuySellChain Zero-Trust

Sistema aste a busta chiusa

Salvucci Franco (0368692), Zbirciog Ionut Georgian (0381279)

Università di Roma Tor Vergata

Giugno 11, 2026



TOR VERGATA
UNIVERSITÀ DEGLI STUDI DI ROMA

Roadmap

- 1 Zone di Sicurezza
- 2 Asset Inventory e Analisi delle criticità
- 3 Baseline
- 4 Logger e Migrazione DB
- 5 Threat Analysis con l'IA

Roadmap

- 1 Zone di Sicurezza
- 2 Asset Inventory e Analisi delle criticità
- 3 Baseline
- 4 Logger e Migrazione DB
- 5 Threat Analysis con l'IA

- **Reverse Proxy:** Load Balancing e gestione connessione sicura (TLS/SSL).
- **Security Gateway:** Backend Python-Flask che gestisce la logica di business.
- **Session/Authentication Manager:** Modulo Flask per la gestione del flusso di autenticazione, autorizzazione e sessione utilizzando JWT (Json Web Token).

- **Rete Hyperledger Fabric:** Infrastruttura Blockchain Permissioned.
- **Smart Contract:** API di interazione con la Blockchain.
- **Client Lisp:** Middleware fra Security Gateway e rete Fabric.

Roadmap

- 1 Zone di Sicurezza
- 2 Asset Inventory e Analisi delle criticità
- 3 Baseline
- 4 Logger e Migrazione DB
- 5 Threat Analysis con l'IA

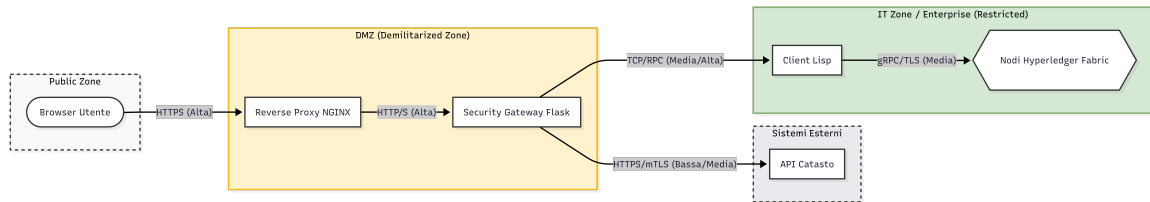
Inventory

Asset	Tipo	Criticità	Dipendenze
Smart Contract	Software	Critica	Fabric
Blockchain	Dati	Critica	Peer Nodes & MSP
Security Gateway	Applicativo	Alta	Internet & Client Lisp
Chiavi Segrete	Crittografia	Estremo	Security Gateway (server)
Frontend	Interfaccia	Media	Internet & Security Gateway
API Catasto	Servizio Esterno	Alta	ISP & Security Gateway

Endpoint del S.G.

Endpoint	Criticità	Note
GET/POST /admin	Critica	Accesso riservato agli admin
GET/POST /assets	Media	Gestione asset immobiliari
GET/POST /auctions	Media	Creazione e consultazione delle aste
GET/POST /bids	Media	Invio e lettura delle offerte
POST /auth	Alta	Emissione e validazione JWT

Grafo dell'Infrastruttura



Roadmap

- 1 Zone di Sicurezza
- 2 Asset Inventory e Analisi delle criticità
- 3 Baseline**
- 4 Logger e Migrazione DB
- 5 Threat Analysis con l'IA

Baseline dei Flussi (1/2)

Relazione Normale	Quando	Intensità	Note
Frontend Web → Security Gateway	Sempre	Alta	Navigazione utenti, login, invio offerte.
Security Gateway → Rete Fabric (via Client Lisp)	Sempre	Media	Invocazione Smart Contract per registrazione aste e offerte.
Security Gateway → API Catasto	Giorno/Notte	Bassa/Media	Verifica validità immobili, chiamate asincrone e sincrone.
Client esterno → Server Gateway	Mai	Nulla	Deviazione topologica grave. Client non-browser che tentano di invocare direttamente lo Smart Contract.

Table 1: Baseline qualitativa dei flussi leciti e applicativi - Connessioni.

Baseline dei Flussi (2/2)

Flussi utente (Seller/Buyer) — baseline applicativa

Flusso	Consentito	Intensità	Note
Login/Registrazione → Crea Asset → Crea Asta	Sì	Normale	Flusso canonico del venditore: autenticazione, onboarding immobile, apertura asta.
Login/Registrazione → Crea Asta	Sì	Normale	Flusso abbreviato se l'asset è già presente nel ledger.
Home Page (no login) → Crea Asta / Crea Asset	No	Deviazione	Accesso a risorse protette senza autenticazione. Contromisura: redirect al login o risposta 403 Forbidden.

Table 2: Baseline qualitativa dei flussi leciti e applicativi - Casi d'uso.

Roadmap

- 1 Zone di Sicurezza
- 2 Asset Inventory e Analisi delle criticità
- 3 Baseline
- 4 Logger e Migrazione DB**
- 5 Threat Analysis con l'IA

- **Eliminazione DB Off-Chain:** Migrazione DB Off-Chain → Blockchain.
- **Motivazioni:** Utilizzo delle proprietà fondamentali della Blockchain (immutabilità, decentralizzazione, sicurezza) per la memorizzazione dei dati sensibili degli Utenti.

- **Ruolo:** Processo di registrazione delle attività, degli errori, o dei passaggi di esecuzione del sistema.
- **Logger (BL):**
 - ▶ Monitoraggio del sistema, dei comportamenti anomali e delle deviazioni dalla baseline
 - ▶ Scrittura dei record on-chain con i relativi dati, quali: route/severity/description,etc...
 - ▶ Cifratura informazioni sensibili (IP sorgente, User-Agent).
- **Logger (Local):**
 - ▶ Usato in fase di sviluppo e debug del codice applicativo.
 - ▶ Scrittura dei log su file.

Struttura del Log JSON

```
{
  "id": hash(description, created_at, level, from_ip, user_agent, method,
    payload_size),
  "description": MessageType,
  "created_at": timestamp,
  "level": INFO/ALERT,
  "from_ip": AES-256-GCM(source IPv4),
  "method": HTTP method,
  "user_agent": AES-256-GCM(useragent),
  "payload_size": N Kb size of payload
}
```


Roadmap

- 1 Zone di Sicurezza
- 2 Asset Inventory e Analisi delle criticità
- 3 Baseline
- 4 Logger e Migrazione DB
- 5 Threat Analysis con l'IA

Modello IA & Threat Analysis

- **Analisi Attiva delle Minacce:** Rilevamento proattivo e identificazione automatizzata di anomalie o pattern d'attacco direttamente tramite l'analisi dei log di sistema.
- **Supporto all'Admin:** Elaborazione dei dati in tempo reale per fornire una prima diagnostica e raccomandazioni utili all'amministratore di sistema.
- **Modello Scelto:** Implementazione locale (per garantire la privacy dei dati sensibili dei log) tramite Ollama con il modello qwen3.5.
- **Infrastruttura di Sicurezza:** Modulo Flask per la gestione sicura del flusso di comunicazione, con controllo di autenticazione, autorizzazione e sessione tramite JWT (Json Web Token).

Disclaimer Importante

L'IA **NON** deve essere utilizzata direttamente per bloccare le minacce e non deve interagire con il codice sorgente. I log vanno sempre analizzati da un **esperto umano** per escludere possibili **falsi positivi/negativi**.